

VAPT Questionnaire — Technical

Document 2 of 2 • For a developer / architect • ~15 minutes

Quoting only — credentials and ROE follow after the proposal is accepted

Integers beat adjectives. Unknown is better than blank. Yellow boxes = your answer.

Highest-value attachments: OpenAPI/Swagger, admin nav, separate Android and iOS screenshots, architecture one-pager.

Quoting only — credentials and Rules of Engagement (ROE) are shared after the proposal is accepted.

1. Context

1.1	Organization + technical contact (name, role, email, phone)	
1.2	Include in this quote	☐ Admin UI ☐ Portal APIs ☐ Android ☐ iOS ☐ Mobile-only APIs ☐ Retest
1.3	Testing type + environment to quote	☐ Gray box (recommended) ☐ Black box ☐ White box (source) Env: ☐ Staging only ☐ Staging+prod ☐ Prod only
1.4	Hard exclusions / deadline	<i>e.g. no production, no DoS, go-live date</i>

2. Architecture (four facts)

2.1	One-line architecture	<i>e.g. React SPA + NestJS + Postgres on AWS; Flutter apps call the same API</i>
2.2	Admin vs mobile backend	☐ Same API ☐ Same backend, different API ☐ Separate stacks
2.3	Cloud / tenancy / how admin is reached	☐ AWS/Azure/GCP/on-prem ☐ Single tenant ☐ Multi-tenant ☐ Public ☐ VPN/allowlist
2.4	Staging ≈ production (features + auth + integrations)?	☐ Yes ☐ No — missing: ____
2.5	Backend language / framework + database	<i>e.g. Node.js/NestJS, PostgreSQL 15, Redis cache</i>

3. Admin + API numbers we price from

3.1	Admin: modules + unique authenticated UI routes/pages	Modules: ____ Pages/routes: ____ (1 template / N records)
3.2	Admin RBAC: role count + names	Count: ____ Names: Super Admin, ... Model: ☐ simple roles ☐ fine-grained ☐ ABAC
3.3	Admin auth + session / API token	☐ Password ☐ MFA ☐ SAML ☐ OIDC (IdP: ____) ☐ Impersonation Token: ☐ cookie ☐ JWT ☐ OAuth2 ☐ API key
3.4	API: style + authenticated routes + public routes + docs	☐ REST ☐ GraphQL AuthN: ____ Public: ____ ☐ Swagger ☐ Postman ☐ None
3.5	Web price drivers present?	☐ SSO ☐ Payments ☐ File/CSV ☐ Multi-tenant ☐ Approvals ☐ WAF (name: ____, allowlist IPs? ☐)

4. Android application (complete fully — do not point at iOS)

If Android is out of scope, write N/A in 4.1 and skip to section 5.

4.1	applicationId + version + Play Store / sideload	<i>com.company.app</i> v_____ ☐ Play ☐ Sideload/MDM ☐ Can supply APK/AAB
4.2	Android framework	☐ Native Kotlin/Java ☐ Flutter ☐ React Native ☐ Other: _____
4.3	Unique Android screens + roles	Screens: _____ Roles: _____ (names)
4.4	Android auth + token storage	☐ OTP ☐ Password ☐ Refresh ☐ Biometric ☐ Social Store: ☐ Keystore ☐ Encrypted prefs ☐ Plain ☐ Unknown
4.5	Android API surface vs admin API	☐ Same API ☐ Subset ☐ Extra Android-only routes (count: _____) ☐ Separate service
	TLS pinning (Android) — can you ship an unpin/debug APK?	☐ Yes ☐ No ☐ Partial
	Root detection / RASP / obfuscation (R8) — name product if known	☐ Yes ☐ No ☐ Partial
	Payments / Play Billing / wallet	☐ Yes ☐ No ☐ Partial
	KYC / camera / file pickers	☐ Yes ☐ No ☐ Partial
	Chat, maps/live location, or offline+local PII — tick Yes if any one applies, note which	☐ Yes ☐ No ☐ Partial
	Deep links, WebView hybrid, or staff flavour — note which	☐ Yes ☐ No ☐ Partial

5. iOS application (complete fully — do not write “same as Android”)

If iOS is out of scope, write N/A in 5.1 and skip to section 6. Count screens on an iPhone/simulator, not by copying section 4.

5.1	Bundle ID + version + App Store / TestFlight / enterprise	<code>com.company.app</code> v____ ☐ Store ☐ TestFlight ☐ Enterprise IPA
5.2	iOS framework	☐ Native Swift/Obj-C ☐ Flutter ☐ React Native ☐ Other: ____
5.3	Unique iOS screens + roles (do not reuse Android counts)	Screens: ____ Roles: ____ (names)
5.4	iOS auth + token storage	☐ OTP ☐ Password ☐ Refresh ☐ Face ID/Touch ID ☐ Social Store: ☐ Keychain ☐ Other ☐ Unknown
5.5	iOS API surface vs admin API	☐ Same API ☐ Subset ☐ Extra iOS-only routes (count: ____) ☐ Separate service
5.6	Deltas vs Android (required)	Features iOS lacks or has extra. Write “compared, none” only after a real check.
	ATS / TLS pinning (iOS) — can you ship an unpin/debug IPA or TestFlight?	☐ Yes ☐ No ☐ Partial
	Jailbreak detection / RASP / obfuscation — name product if known	☐ Yes ☐ No ☐ Partial
	Payments / StoreKit / wallet	☐ Yes ☐ No ☐ Partial
	KYC / camera / file pickers	☐ Yes ☐ No ☐ Partial
	Chat, maps/live location, or offline+local PII — tick Yes if any one applies, note which	☐ Yes ☐ No ☐ Partial
	Universal Links, WebView hybrid, or MDM-only — note which	☐ Yes ☐ No ☐ Partial

6. Testing logistics & prior assessments

6.1	Has this system been pen-tested before? When, by whom, and were findings fixed?	e.g. "Yes, Q1 2025, all High/Critical closed" or "Never tested"
6.2	Is a compliance certificate or approval driving this test? (e.g. RBI, PCI-DSS, ISO 27001, SOC2, client mandate)	Name it + deadline, if any — this decides the report format we prepare
6.3	Any WAF / IPS / bot-protection / rate-limiting active that could block or flag our scans?	Name product: ____ ☐ Will allowlist tester IPs ☐ Not sure ☐ None
6.4	Will test accounts (one per role) and sample data be ready before testing starts?	☐ Yes, will provision ☐ Need help deciding ☐ Not sure
6.5	Blackout dates / freeze windows to avoid (releases, peak load, change freeze)	e.g. "no testing 20–31 Dec" or "none"

7. Attach + leftovers

7.1	Attaching now	☐ Diagram ☐ OpenAPI ☐ Admin nav ☐ Android screenshots ☐ iOS screenshots ☐ RBAC matrix
7.2	Anything that would change effort if we missed it	New module, white-label skins, iOS behind Android, GraphQL introspection off

Accurate enough to quote. Access and signed authorisation follow acceptance.

Name / role	Date
-------------	------